■■ CONFIDENTIAL DOCUMENT // FACULTY & HOST EYE ONLY • DO NOT DISTRIBUTE TO PARTICIPANTS

■ MARIO: THE CYBER HEIST — SOLUTION CHEAT SHEET

Chanakya University • OJAS Tech Fest 2026 | Complete Forensic Solutions, Vulnerability Explanations ('Why') & Exploitation Guides ('How to Crack')

■ **Host Terminal Access:** Navigate to http://127.0.0.1:5000/admin (or /leaderboard). **Passkeys:** OJAS-HOST-ALPHA-7701 (Primary), OJAS-HOST-BRAVO-9924 (Co-Host), OJAS-HOST-SUPER-4418 (Superadmin). Emergency fallback: OJAS_ADMIN_2026.

■ Master Quick-Reference Summary Table

Quickly look up case numbers, categories, flags, and sector shield keywords for immediate reference during live rounds.

Case	Challenge Title	Sector	Category	Points	Exact Flag String	Shield Key
#1	The Broken Notice Board	S1: Village	Web / DOM	100	`FLAG{MUSHROOM_SECRET_OJAS_2026}`	`SECRET`
#2	The Suspicious Intercept	S1: Village	Cryptography	150	`FLAG{LETTER_CIPHER_SOLVED_OJAS}`	—
#3	Deep Glitch in the Pines	S2: Forest	Steganography	200	`FLAG{FOREST_PIXEL_STEGO_OJAS}`	`PINES`
#4	The Shadow Metadata Trail	S2: Forest	OSINT / EXIF	200	`FLAG{METADATA_TRAIL_REVEALED_OJAS}`	—
#5	Corrupted Proxy Stream	S2: Forest	Net Forensics	250	`FLAG{DARK_FOREST_STREAM_DECODED}`	—
#6	Phantom Directory Traversal	S3: Mansion	Web Security	250	`FLAG{BOO_GHOST_PATH_DISCOVERED}`	—
#7	Boo's Vault IDOR Manipulation	S3: Mansion	API Security	300	`FLAG{API_AUTH_BYPASS_OJAS}`	`BOO`
#8	Poltergeist Session Forgery	S3: Mansion	JWT Token	300	`FLAG{SESSION_FORGERY_DETECTED_OJAS}`	—
#9	The Framed Shellshock Recon	S4: Koopa HQ	Host Forensics	350	`FLAG{SHELLSHOCK_WAS_FRAMED_OJAS}`	—
#10	Correlated SIEM Log Breaches	S4: Koopa HQ	Threat Hunting	350	`FLAG{CORRELATED_LOGS_INSIDER_OJAS}`	`INSIDER`
#11	Fortress Mainframe SQLi	S4: Koopa HQ	SQL Injection	400	`FLAG{SQLI_ARCHIVE_UNLOCKED_OJAS}`	—
#12	Mecha-Shellshock Showdown	S5: Fortress	Master Boss	500	`FLAG{GOLDEN_STAR_RESTORED_OJAS_CHAMPION}`	`4 KEYS`

■ Case-by-Case Deep Dive: 'Why' (Vulnerability) & 'How to Crack' (Exploit Walkthrough)

Each case is categorized with technical rationale explaining the vulnerability class, along with the precise tactical steps required to solve it.

Case #1: The Broken Notice Board | *Sector 01: Mushroom Village (Ground Zero)*

Category: Web Security & Client DOM Forensics • Reward: 100 PTS | +1 ■ | +50 ■

EXACT FLAG: `FLAG{MUSHROOM_SECRET_OJAS_2026}` | BOSS SHIELD KEY: SECRET

WHY (Vulnerability Analysis): Insecure Information Disclosure in Source Comments (CWE-615): Developers routinely leave staging tokens, comments, and debug values inside client-facing HTML. Because the browser downloads the raw HTML markup before rendering, comments (<!-- ... -->) are never executed as logic but remain completely readable by anyone inspecting the DOM.

HOW TO CRACK (Exploitation Steps): 1. In the challenge workbench, click **[TOGGLE DOM TREE INSPECTOR]** (or press F12 in standard dev tools).
2. Inspect the HTML structure inside container #village-bulletin-board.
3. Locate line 94: <!-- cyber-heist-token: FLAG{MUSHROOM_SECRET_OJAS_2026} -->.
4. Note the sector keyword **SECRET** for the World 5 Boss Shield.

Case #2: The Suspicious Intercept | *Sector 01: Mushroom Village (Ground Zero)*

Category: Classical Cryptography (Monoalphabetic Substitution) • Reward: 150 PTS | +1 ■ | +75 ■

EXACT FLAG: `FLAG{LETTER_CIPHER_SOLVED_OJAS}`

WHY (Vulnerability Analysis): Weak Obfuscation / Insecure Classical Cipher (CWE-327): The adversary intercepted traffic and attempted to hide intelligence using ROT-13 (Caesar shift by 13). ROT-13 offers zero cryptographic entropy because the key space is fixed ($k=13$). Modern forensics easily breaks substitution ciphers by observing the known-plaintext prefix SYNT -> FLAG.

HOW TO CRACK (Exploitation Steps): 1. Observe the ciphertext: SYNT{YRGGRE_PVCURE_FBYIRQ_BWNF}.
2. Calculate the alphabet distance between 'S' and 'F' ($19 - 6 = 13$ mod 26).
3. In the interactive decoder workbench, drag the **CAESAR ROTATION SHIFT** slider to **13**.
4. The deciphered text instantly turns bright green: FLAG{LETTER_CIPHER_SOLVED_OJAS}.

Case #3: Deep Glitch in the Pines | *Sector 02: Dark Forest (Digital Woods • Requires 2 ■)*

Category: Steganography & LSB Bitplane Concealment • Reward: 200 PTS | +1 ■ | +100 ■

EXACT FLAG: FLAG{FOREST_PIXEL_STEGO_OJAS} | BOSS SHIELD KEY: PINES

WHY (Vulnerability Analysis): Least Significant Bit (LSB) Steganography: Digital images store color as 8-bit values per channel (0–255). Modifying only the lowest bit (Bit 0) alters the RGB color by a mere $1/256$, which is imperceptible to the human eye. Attackers exploit this perceptual threshold to conceal binary ASCII streams inside high-resolution raster images.

HOW TO CRACK (Exploitation Steps): 1. Open the drone surveillance viewer in Case 3.
2. Toggle through the bitplane filter buttons located underneath the image canvas.
3. Click **[GREEN PLANE]** or **[LSB BITPLANE 0]**.
4. The image contrast strips away high-order pixels, exposing the hidden fluorescent ASCII text: BITPLANE 0 CONCEALED: FLAG{FOREST_PIXEL_STEGO_OJAS}.
5. Note the sector keyword **PINES** for Boss Shield 2.

Case #4: The Shadow Metadata Trail | *Sector 02: Dark Forest (Digital Woods • Requires 2 ■)*

Category: OSINT & Forensic Artifact Analysis (EXIF) • Reward: 200 PTS | +1 ■ | +100 ■

EXACT FLAG: FLAG{METADATA_TRAIL_REVEALED_OJAS}

WHY (Vulnerability Analysis): File Header & Metadata Information Leakage (CWE-200): Modern media standards (JPEG, TIFF, PDF) append rich technical metadata headers (EXIF, IPTC, XMP) containing timestamps, camera sensor models, GPS coordinates, and user comments. Failing to scrub EXIF tags during file export leaves an indelible forensic breadcrumb trail.

HOW TO CRACK (Exploitation Steps): 1. In Case 4, inspect the **RAW EXIF METADATA TERMINAL**.
2. Scroll through standard EXIF tags (Aperture, ShutterSpeed, FocalLength).
3. Examine the bottom vendor tags: Software: CyberHeist_Stealth_Encoder and UserComment: FLAG{METADATA_TRAIL_REVEALED_OJAS}.
4. Copy the flag directly from the comment field.

Case #5: Corrupted Proxy Stream | *Sector 02: Dark Forest (Digital Woods • Requires 2 ■)*

Category: Network Protocol & Packet Stream Hexdump Analysis • Reward: 250 PTS | +1 ■ | +125 ■

EXACT FLAG: FLAG{DARK_FOREST_STREAM_DECODED}

WHY (Vulnerability Analysis): Cleartext Network Transmission (CWE-319): The rogue proxy intercepted an outgoing TCP socket stream without TLS/SSL encryption. Even though presented as raw hex bytes, cleartext traffic payloads retain direct 1-to-1 ASCII character equivalence, allowing network analysts to reconstruct protocol payloads via hexadecimal decoding.

HOW TO CRACK (Exploitation Steps): 1. Inspect the captured raw hex dump: 46 4c 41 47 7b 44 41 52 4b 5f 46 4f 52 45 53 54 ... 7d.
2. Recognize the standard ASCII prefix: $0x46 = 'F', 0x4C = 'L', 0x41 = 'A', 0x47 = 'G', 0x7B = '\{'$.
3. Convert the 32 hex pairs into ASCII using the built-in workbench decoder or Python bytes.fromhex(...).
4. Output yields: FLAG{DARK_FOREST_STREAM_DECODED}.

Case #6: Phantom Directory Traversal | *Sector 03: Haunted Mansion (Phantom Network • Requires 5 ■)*

Category: Web Security: Information Disclosure & Path Traversal • Reward: 250 PTS | +1 ■ | +125 ■

EXACT FLAG: FLAG{BOO_GHOST_PATH_DISCOVERED}

WHY (Vulnerability Analysis): Predictable Resource Location & Disclosed Sensitive Endpoints (CWE-538): Web administrators frequently attempt 'security through obscurity' by adding hidden directories to robots.txt to stop search crawlers. Attackers actively read robots.txt to locate sensitive backup archives (.bak), which are often hosted with improper directory traversal access controls.

HOW TO CRACK (Exploitation Steps): 1. In the Mansion File Explorer, type path /robots.txt and click **FETCH**.
2. Read the crawler directive: Disallow: /secret_attic/ # Note: ghost_manifesto.bak contains sector vault key.
3. Change the input path to /secret_attic/ghost_manifesto.bak and click **FETCH**.
4. The server returns the leaked backup document displaying: FLAG{BOO_GHOST_PATH_DISCOVERED}.

Case #7: Boo's Vault IDOR Manipulation | *Sector 03: Haunted Mansion (Phantom Network • Requires 5 ■)*

Category: API Security: Broken Object Level Authorization (IDOR) • Reward: 300 PTS | +1 ■ | +150 ■

EXACT FLAG: FLAG{API_AUTH_BYPASS_OJAS} | BOSS SHIELD KEY: BOO

WHY (Vulnerability Analysis): Insecure Direct Object Reference / BOLA (OWASP API1): The REST API endpoint accepts an object ID directly from the client request (locker_id) and an access-tier header (X-Access-Level). Because the backend fails to validate whether the authenticated session actually owns locker #0001, an attacker simply swaps the ID to access unauthorized data.

HOW TO CRACK (Exploitation Steps): 1. Observe the default client parameters: Guest locker is 1042 with header X-Access-Level: guest_phantom.
2. Modify parameter locker_id to VIP vault **1**.
3. Modify the HTTP header to X-Access-Level: master_phantom.
4. Click **[SEND INTERCEPTED API REQUEST]**.
5. King Boo's Vault #0001 opens, releasing: FLAG{API_AUTH_BYPASS_OJAS}.
6. Note the sector keyword **BOO** for Boss Shield 3.

Case #8: Poltergeist Session Forgery | *Sector 03: Haunted Mansion (Phantom Network • Requires 5 ■)*

Category: Token Exploitation: JWT Algorithm Confusion (None Alg) • Reward: 300 PTS | +1 ■ | +150 ■

EXACT FLAG: FLAG{SESSION_FORGERY_DETECTED_OJAS}

WHY (Vulnerability Analysis): JWT 'alg: none' Signature Verification Bypass (CWE-347): JSON Web Tokens rely on the header "alg" field to determine how to verify signatures. In insecure implementations, setting "alg": "none" triggers the server to treat the token as unsigned, accepting arbitrary tampering in the payload (elevating role: guest to role: admin) without verifying any cryptographic signature.

HOW TO CRACK (Exploitation Steps): 1. In the JWT Token Forge workbench, switch **TOKEN ROLE** to **admin**.
2. Switch **SIGNATURE ALGORITHM (alg)** from HS256 (Signed) to **none (Unsigned Bypass)**.
3. Notice the signature hash is stripped: eyJhbGciOiJub25lIn0... ..
4. Click **[TRANSMIT FORGED SESSION COOKIE]**.
5. The server accepts the forged admin cookie and unlocks: FLAG{SESSION_FORGERY_DETECTED_OJAS}.

Case #9: The Framed Shellshock Recon | *Sector 04: Koopa HQ (Industrial Bastion • Requires 8 ■)*

Category: Operating System & Host Artifact Forensics • Reward: 350 PTS | +1 ■ | +175 ■

EXACT FLAG: FLAG{SHELLSHOCK_WAS_FRAMED_OJAS}

WHY (Vulnerability Analysis): Persistence Backdoor & Log Evasion Analysis: Adversaries who compromise Linux environments often implant persistence hooks inside user shell termination and profile scripts (e.g., ~/.bash_logout, ~/.profile). Inspecting these hidden files reveals command-and-control communication strings and forensic evidence proving Shellshock was framed.

HOW TO CRACK (Exploitation Steps): 1. In Case 9, run forensic investigation on the compromised Koopa host.
2. Inspect the contents of cat /home/shellshock/.bash_logout.bak.
3. Locate the embedded reverse shell payload timestamped 48 hours prior to the heist.
4. Extract the token string: FLAG{SHELLSHOCK_WAS_FRAMED_OJAS}.

Case #10: Correlated SIEM Log Breaches | *Sector 04: Koopa HQ (Industrial Bastion • Requires 8 ■)*

Category: Threat Hunting & Log Correlation Analysis • Reward: 350 PTS | +1 ■ | +175 ■

EXACT FLAG: FLAG{CORRELATED_LOGS_INSIDER_OJAS} | BOSS SHIELD KEY: INSIDER

WHY (Vulnerability Analysis): Anomalous User-Agent & Query Correlation (MITRE ATT&CK; T1071): Massive SIEM access logs conceal attacks inside high-volume noise. Threat hunters filter out 401/403/404 noise and isolate pivot IP addresses (10.99.13.37). Attackers using bespoke scripts frequently broadcast identifiable User-Agent strings and exploit parameters in the access stream.

HOW TO CRACK (Exploitation Steps): 1. In the SIEM analyzer, apply the filter: IP=10.99.13.37 AND STATUS=200.
2. Review the correlated HTTP GET requests hitting /internal/admin/override.
3. Inspect the User-Agent header: User-Agent: Insider-Infiltrator/1.0 (FlagPayload: FLAG{CORRELATED_LOGS_INSIDER_OJAS}).
4. Note the threat tag parameter **INSIDER** for Boss Shield 4.

Case #11: Koopa Fortress Mainframe Bypass | *Sector 04: Koopa HQ (Industrial Bastion • Requires 8 ■)*

Category: Database Exploitation: SQL Injection (SQLi Tautology) • Reward: 400 PTS | +1 ■ | +200 ■

EXACT FLAG: FLAG{SQLI_ARCHIVE_UNLOCKED_OJAS}

WHY (Vulnerability Analysis): Classic SQL Injection via Dynamic Query Concatenation (CWE-89): The application constructs backend database queries via raw string interpolation: SELECT * FROM employees WHERE badge_id = '{input}'. Injecting a boolean tautology (' OR '1'='1) alters the AST syntax so the WHERE clause evaluates to true for every single row in the database table.

HOW TO CRACK (Exploitation Steps): 1. In the Koopa Security Badge terminal, enter the standard bypass tautology: **' OR '1'='1** (or ' OR 1=1 --).
2. Click **[QUERY DB]**.
3. The database evaluates the condition as universally true, dumping all employee records.
4. Root admin record #999 reveals the archive token: FLAG{SQLI_ARCHIVE_UNLOCKED_OJAS}.

Case #12: Mecha-Shellshock Showdown (Master Core) | *Sector 05: Final Fortress (Master Vault • Requires 11 ■)*

Category: Master Forensic Synthesis & 3D Boss Battle • Reward: 500 PTS | +2 ■ | +300 ■

EXACT FLAG: FLAG{GOLDEN_STAR_RESTORED_OJAS_CHAMPION} | BOSS SHIELD KEY: ALL 4 KEYS

WHY (Vulnerability Analysis): Multi-Vector Cryptographic Defense Synthesis: The Final Boss represents an integrated defense-in-depth perimeter. Its quantum shields cannot be bypassed with brute force; they require reconstructing the 4 intelligence keywords collected across the previous 4 sectors: DOM comment keyword, stego ridge name, VIP vault owner, and internal threat tag.

HOW TO CRACK (Exploitation Steps): 1. Overcome Shield 1 (Sector 01 Keyword): **SECRET**
2. Overcome Shield 2 (Sector 02 Keyword): **PINES**
3. Overcome Shield 3 (Sector 03 Keyword): **BOO**
4. Overcome Shield 4 (Sector 04 Keyword): **INSIDER**
5. Neutralizing Shield 4 causes Mecha-Shellshock to collapse in 3D, unlocking the vault and **automatically displaying the Master Flag**: FLAG{GOLDEN_STAR_RESTORED_OJAS_CHAMPION}.
6. Submit the Master Flag to freeze the competition clock and win the tournament!

■■ Host Live Operations & Troubleshooting Quick-Guide

Scenario	Host Resolution / Action
Participant Forgot Access Code	Open /admin -> Tab 1. Locate student row. The chip OJAS-XXXXXX ■ can be clicked to copy their code. Alternatively, students can resume directly using their registered **Register Number / USN** on the briefing screen.
Participant Stuck on Boss Battle	Confirm they entered the 4 sector shield keywords: SECRET (Case 1), PINES (Case 3), BOO (Case 7), INSIDER (Case 10). Neutralizing all 4 triggers automatic flag reveal.
Student Accidentally Concluded Mission Early	Direct the student to /end (Debrief page). They can click **'■ REOPEN / RESUME MISSION'** to unfreeze their timer and continue playing where they left off.
Live Leaderboard Inspection	Leaderboard is strictly restricted to hosts at /leaderboard. Enter any Host Passkey (OJAS-HOST-ALPHA-7701) to view rankings sorted by Score DESC -> Stars DESC -> Time ASC.
Reset Competition to Factory Clean State	In /admin -> Tab 4, click **'■■ FACTORY RESET CTF DATABASE'** (or call admin_reset_system()). Wipes all test squads and resets the competition state to LOBBY with 0 teams.